

Cirque Corporation

Information Security Policy - Internal Parties

Document ID: IS-CIRQ-P-001-A-G

Category: Information Security

Division: Global

Type: Policy Annex

Version: 1.0

Effective Date: 2026-03-02

Review Date: 2027-03-02

Approved By: Chris Wren, CISO

Generated: March 02, 2026

1. Purpose and Scope

This annex to the Cirque Corporation Information Security Policy (IS-CIRQ-P-001-G) defines specific information security requirements, responsibilities, and obligations for internal parties.

Internal parties include:

- All employees (full-time, part-time, temporary)
- Contractors and consultants working on Cirque premises or with Cirque systems
- Board members and executives
- Interns and trainees
- Any individual with access to Cirque information systems or data

This policy applies to all information security activities performed by internal parties, including but not limited to:

- Access to information systems and data
- Handling of confidential and sensitive information
- Use of company-provided and personal devices
- Remote work and mobile computing
- Email and communication systems

- Physical security compliance
- Incident reporting obligations

2. Information Security Responsibilities

All internal parties have the following information security responsibilities:

General Responsibilities:

- Comply with all information security policies, procedures, and standards
- Protect confidential and proprietary information from unauthorized disclosure
- Report suspected security incidents, vulnerabilities, or policy violations immediately
- Complete required information security training within specified timeframes
- Maintain awareness of current security threats and protective measures
- Use strong passwords and protect authentication credentials
- Lock workstations when leaving them unattended
- Follow clean desk and clear screen policies

Data Protection:

- Handle all data according to its classification level
- Encrypt sensitive data in transit and at rest as required
- Never share, transmit, or store data in violation of policy
- Properly dispose of confidential information using approved methods
- Understand and comply with data privacy regulations (GDPR, CCPA, etc.)

Access Control:

- Use only authorized systems and networks
- Access only data necessary for job functions
- Never share user accounts, passwords, or authentication tokens
- Report lost or stolen credentials immediately
- Respect access controls and never attempt to bypass security measures

3. Acceptable Use Requirements

Internal parties must comply with the following acceptable use requirements:

Authorized Use:

- Use company information systems only for legitimate business purposes
- Personal use must be minimal and not interfere with work responsibilities
- No use of company resources for illegal, unethical, or inappropriate activities
- No accessing, downloading, or distributing inappropriate content

Prohibited Activities:

- Attempting to gain unauthorized access to systems or data
- Installing unauthorized software or hardware
- Circumventing security controls or monitoring systems
- Using company resources for personal business ventures
- Engaging in activities that could damage company reputation
- Sending spam, chain letters, or unauthorized mass communications
- Using peer-to-peer file sharing or unauthorized cloud storage
- Cryptocurrency mining or running personal servers

Internet and Email:

- Use corporate email for business communications
- Be cautious of phishing attempts and social engineering
- Do not open suspicious attachments or click unknown links
- Maintain professional tone in all business communications
- Do not use personal email for company business
- Understand that company systems may be monitored

Social Media:

- Do not disclose confidential company information on social media
- Be clear when personal opinions do not represent the company
- Follow company social media policy and guidelines
- Report any security concerns observed on social media

4. Remote Work and Mobile Device Security

Internal parties working remotely or using mobile devices must:

Remote Work Requirements:

- Use approved VPN connections when accessing company systems remotely
- Ensure home networks have WPA2/WPA3 encryption and strong passwords
- Maintain physical security of company equipment in remote locations
- Prevent unauthorized viewing of screens or documents by family/visitors
- Use only approved collaboration tools and file sharing services
- Report any security concerns in remote work environment

Mobile Device Security:

- Enable device encryption on all mobile devices accessing company data
- Use strong passcodes or biometric authentication
- Enable remote wipe capability for company-issued devices
- Keep devices updated with latest security patches
- Never leave devices unattended in public places
- Report lost or stolen devices immediately
- Do not jailbreak or root company devices
- Use only approved apps for accessing company data

BYOD (Bring Your Own Device):

- Personal devices accessing company data must meet minimum security requirements
- Install required mobile device management (MDM) software
- Understand that company data on personal devices may be remotely wiped
- Keep personal and business data appropriately separated
- Comply with all mobile device policies

5. Physical Security Responsibilities

Internal parties must maintain physical security:

Facility Access:

- Use assigned access badges at all times when on company premises
- Never share access badges or prop open secure doors
- Challenge or report unknown individuals in secure areas

- Report lost or stolen access badges immediately
- Escort visitors and ensure they sign in/out properly
- Lock offices and secure areas when unattended

Equipment Security:

- Lock laptops using cable locks when in public areas or offices
- Store mobile devices securely when not in use
- Never leave equipment unattended in vehicles or public places
- Label all company equipment with asset tags
- Return all company equipment upon separation from employment

Document Security:

- Secure confidential documents in locked drawers or cabinets
- Never leave sensitive documents on printers or fax machines
- Shred confidential documents using approved methods
- Follow clean desk policy at end of workday
- Protect physical records from unauthorized access

Visitor Management:

- Visitors must be escorted at all times in secure areas
- Visitors must wear visitor badges visibly
- Do not allow visitors access to sensitive systems or data
- Report visitors behaving suspiciously

6. Confidential Information Protection

Internal parties must protect confidential information:

Classification and Handling:

- Understand data classification scheme (Confidential, Internal, Public)
- Handle data according to its classification level
- Never discuss confidential matters in public or unsecured locations
- Use encrypted channels for transmitting sensitive information
- Limit access to confidential information on need-to-know basis

Non-Disclosure Obligations:

- All employees sign Non-Disclosure Agreements (NDAs) upon hire
- NDAs remain in effect during and after employment
- Never disclose confidential information to unauthorized parties
- Understand legal and financial consequences of unauthorized disclosure
- Obligations continue after employment ends

Intellectual Property:

- All work products created during employment are company property
- Inventions, designs, and code developed belong to the company
- Do not use company intellectual property for personal benefit
- Respect intellectual property rights of others
- Do not bring confidential information from previous employers

Third-Party Information:

- Protect customer and partner confidential information
- Honor third-party NDAs and confidentiality agreements
- Never disclose third-party information without authorization
- Apply same protections to third-party data as company data

7. Incident Reporting Obligations

All internal parties must immediately report:

Security Incidents:

- Suspected malware infections or compromised systems
- Lost or stolen devices containing company data
- Unauthorized access attempts or suspicious activity
- Data breaches or potential data exposure
- Phishing emails or social engineering attempts
- Physical security breaches or unauthorized access

Reporting Procedures:

- Report incidents to IT Support or Security Team immediately
- For critical incidents, escalate to CISO or management
- Do not attempt to investigate or fix security incidents independently
- Preserve evidence and do not delete logs or files
- Document what occurred, when, and what was observed
- Cooperate fully with incident response procedures

Whistleblower Protections:

- No retaliation for reporting security concerns in good faith
- Anonymous reporting channel available when appropriate
- Protection for reporting violations of law or policy
- Obligation to report suspected fraud or misconduct

No Concealment:

- Never attempt to hide or conceal security incidents
- Timely reporting can minimize damage and facilitate response
- Failure to report may result in disciplinary action
- Cooperation with investigations is mandatory

8. Training and Awareness Requirements

Internal parties must complete required training:

Mandatory Training:

- Information Security Awareness training upon hire
- Annual security awareness refresher training
- Role-specific training for privileged access users
- Privacy and data protection training (GDPR, CCPA)
- Phishing awareness and simulation exercises
- Physical security and clean desk training

Training Topics Include:

- Password security and authentication
- Recognizing phishing and social engineering

- Data classification and handling procedures
- Incident reporting procedures
- Mobile device and remote work security
- Acceptable use policies
- Privacy regulations compliance

Acknowledgment:

- Employees must acknowledge receipt and understanding of policies
- Training completion tracked and reported to management
- Failure to complete training may result in access suspension
- Refresher training required when policies updated
- Testing may be required to verify understanding

9. Monitoring and Audit

Internal parties must understand monitoring and audit practices:

System Monitoring:

- Company reserves right to monitor all systems and communications
- Email, internet usage, and file access may be monitored
- No expectation of privacy when using company systems
- Monitoring performed for security, compliance, and business purposes
- Personal use of company systems subject to monitoring

Audit Compliance:

- Internal parties must cooperate with internal and external audits
- Access to systems and documents may be reviewed during audits
- Audit findings must be addressed promptly
- Non-compliance findings may result in disciplinary action
- Management review of audit results conducted regularly

Access Reviews:

- User access rights reviewed quarterly
- Managers must verify appropriateness of access for their teams

- Excessive or unnecessary access removed promptly
- Privileged access subject to enhanced monitoring and review
- Terminated employee access revoked immediately

10. Password and Authentication Requirements

Internal parties must follow password and authentication requirements:

Password Standards:

- Minimum 12 characters for standard accounts
- Minimum 16 characters for privileged/admin accounts
- Use combination of uppercase, lowercase, numbers, and special characters
- Never use common words, names, or easily guessed passwords
- Do not reuse passwords across multiple accounts or systems

Password Protection:

- Never share passwords with anyone, including IT staff
- Never write down passwords in unsecured locations
- Use password manager for storing complex passwords
- Change passwords if compromise suspected
- Default passwords must be changed immediately

Multi-Factor Authentication (MFA):

- MFA required for remote access, email, and sensitive systems
- Use approved MFA methods (authenticator app, hardware token)
- Protect MFA devices and backup codes
- Report lost or compromised MFA devices immediately
- Never share MFA codes or approve suspicious MFA requests

Account Security:

- Lock screens when stepping away from workstation
- Automatic logout after 15 minutes of inactivity
- Report suspicious account activity immediately
- Review recent account activity regularly

- Use separate accounts for administrative functions

11. Software and System Usage

Internal parties must comply with software and system usage requirements:

Approved Software:

- Use only approved and licensed software
- Submit requests for new software through IT approval process
- Do not install unauthorized software or browser extensions
- Ensure all software is properly licensed
- Software piracy strictly prohibited

System Administration:

- Do not attempt to escalate privileges or gain administrative access
- System configuration changes require IT authorization
- Do not disable security software (antivirus, firewall, etc.)
- Keep systems updated with latest security patches
- Report unusual system behavior to IT immediately

Cloud Services:

- Use only approved cloud services and applications
- Do not upload company data to unauthorized cloud storage
- Follow data residency and sovereignty requirements
- Ensure cloud services meet company security standards
- IT must approve and configure cloud service integrations

Personal Devices:

- Personal devices accessing company data must meet security standards
- Register personal devices with IT before accessing company systems
- Install required security software and configurations
- Understand company may require remote wipe of business data
- Keep personal and business data segregated

12. Email and Communication Security

Internal parties must follow email and communication security practices:

Email Security:

- Be vigilant for phishing and spear-phishing attempts
- Verify sender identity before responding to sensitive requests
- Never click links or open attachments from unknown senders
- Use encryption for sending sensitive information via email
- Report suspicious emails to IT Security immediately
- Do not forward company emails to personal accounts

Communication Tools:

- Use approved collaboration platforms (Teams, Slack, etc.)
- Enable encryption for video conferences when discussing sensitive topics
- Do not share meeting links or passwords publicly
- Be aware of who can see or hear conversations
- Use appropriate channels for different classification levels

Voice and Chat:

- Do not discuss confidential matters on unsecured phone lines
- Be cautious when using personal phones for business calls
- Use company-approved messaging platforms
- Chat messages may be archived and monitored
- Professional behavior expected in all communications

Data Transmission:

- Use secure file transfer methods for large files
- Encrypt sensitive data before transmission
- Verify recipient email addresses before sending
- Use secure disposal methods for electronic media
- Be cautious of data loss prevention (DLP) policy violations

13. Separation and Termination

Internal parties must comply with separation procedures:

Notice of Separation:

- Employees must provide appropriate notice when leaving company
- Early notification helps ensure proper offboarding
- Return of company property required before final paycheck
- Exit interview will cover security obligations
- Non-disclosure obligations continue after employment

Return of Company Property:

- All laptops, mobile devices, and equipment must be returned
- Access badges and keys returned to HR or Security
- Company credit cards and procurement cards returned
- Vehicle and parking permits returned if applicable
- All company documents and files returned (physical and electronic)

Access Termination:

- System access terminated on separation date
- Email forwarding may be enabled for business continuity
- Personal files must be removed before separation
- No accessing company systems after termination
- Attempts to access after termination may be prosecuted

Post-Employment Obligations:

- Confidentiality and non-disclosure obligations continue indefinitely
- Non-compete and non-solicitation agreements remain in effect
- Do not retain copies of company confidential information
- Return or destroy any company data in personal possession
- Contact company if approached for company information

14. Policy Violations and Disciplinary Action

Violations of this policy may result in disciplinary action:

Types of Violations:

- Unauthorized access to systems or data
- Failure to report security incidents
- Sharing credentials or unauthorized disclosure
- Installing malicious software or unauthorized tools
- Violating acceptable use policies
- Non-compliance with training requirements
- Deliberate circumvention of security controls

Disciplinary Actions:

- Verbal warning for minor first-time violations
- Written warning and mandatory training
- Suspension of system access privileges
- Performance improvement plan
- Suspension without pay
- Termination of employment
- Legal action and criminal prosecution when appropriate

Investigation Process:

- All reported violations investigated promptly
- Due process provided to all parties
- Cooperation with investigations mandatory
- Evidence preserved and documented
- Results reported to management
- Lessons learned incorporated into training

Factors Considered:

- Severity and impact of violation
- Intent (accidental vs. deliberate)
- Prior violation history

- Level of cooperation during investigation
- Potential harm to company or customers
- Legal and regulatory implications

15. Legal and Regulatory Compliance

Internal parties must support legal and regulatory compliance:

Compliance Obligations:

- Understand applicable laws and regulations (GDPR, CCPA, HIPAA, etc.)
- Handle personal data in compliance with privacy laws
- Maintain records retention according to legal requirements
- Support legal hold and e-discovery requests
- Never delete or modify data subject to legal hold

Data Privacy:

- Process personal data only for legitimate business purposes
- Respect individual privacy rights and data subject requests
- Implement privacy by design in systems and processes
- Report privacy incidents to Data Protection Officer
- Complete data privacy impact assessments when required

Records Management:

- Follow records retention schedules
- Do not prematurely destroy business records
- Use approved methods for data destruction
- Understand litigation hold obligations
- Maintain accurate and complete records

Cooperation:

- Cooperate with legal counsel and compliance teams
- Provide information for regulatory audits
- Report suspected violations of law or regulation
- Attend depositions and provide testimony when required

- Maintain confidentiality of legal matters

16. Policy Acknowledgment and Compliance

All internal parties must acknowledge this policy:

Acknowledgment Requirements:

- Sign written or electronic acknowledgment upon hire
- Re-acknowledge after significant policy updates
- Acknowledgment documented in personnel file
- Refusal to acknowledge may prevent system access
- Acknowledgment indicates understanding and agreement to comply

Review and Updates:

- Policy reviewed and updated annually
- Internal parties notified of significant changes
- Training updated to reflect policy changes
- Questions directed to IT Security or Human Resources
- Suggestions for policy improvements welcomed

Compliance Verification:

- Periodic audits verify policy compliance
- Managers responsible for team compliance
- Compliance reports provided to executive management
- Non-compliance addressed through corrective action
- Continuous improvement of security culture

Contact Information:

- IT Security Team: security@cirque.com
- CISO: Chris Wren, chris.wren@cirque.com
- Human Resources: hr@cirque.com
- Data Protection Officer: dpo@cirque.com
- IT Support: support@cirque.com